Design for secure AI adoption and DevSecOps



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



Globomantics marketing pastes customer data into a chatbot

The AI pilot has no approved data boundary

Security reviews releases on the Thursday before they ship

What does the architect approve, and what blocks?

Design a strategy for secure AI adoption

CAF extends to AI adoption, in six phases

Strategy: AI security objectives and RAI principles

Plan: skills gaps and AI-specific controls

Ready: secure infrastructure and AI security baselines

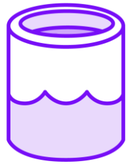
Govern: AI governance policies and risk management

Secure: discover risks, protect resources, detect threats

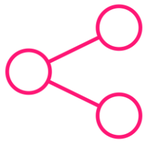
Manage: monitor for threats, maintain posture



What the architect decides before production



The data boundary, and which data may reach the model



The shared responsibility line: IaaS, PaaS, or SaaS



Which AI risks enter the existing threat model



How AI alerts reach the SOC and the playbooks

Responsible AI gives the boundaries a name

Fairness

Reliability and safety

Privacy and security

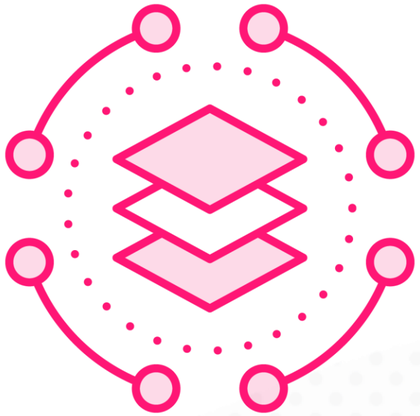
Inclusiveness

Transparency

Accountability

Design a DevSecOps process

Security attaches at four stages



Secure the design

- Threat modeling
- IDE plugins
- Precommit hooks

Secure the code

- Vulnerability scanning in the repository

Secure the pipeline

- Automation and standardization in build and release

Secure operations

- Infrastructure scanning and penetration testing

Shift left: what actually changes

Traditional	vs.	Shift-left
Security review at release		**Threat modeling during planning**
Manual security testing		**Automated security scanning in CI**
Remediation in production		**Vulnerability fixes during development**
Security as a gate		**Security as continuous feedback**

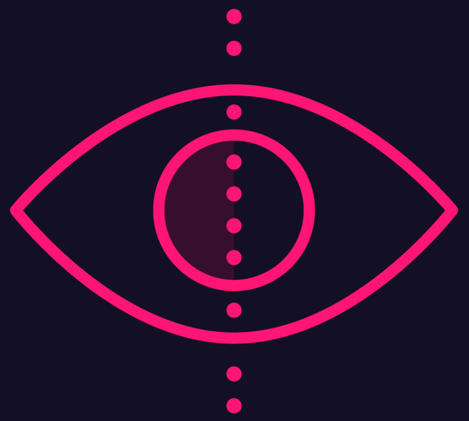
Microsoft Learn, CAF Secure methodology and DevSecOps

“Manual security gates are replaced by automated controls embedded in CI/CD pipelines”

Microsoft Learn, “Design secure DevSecOps processes”, **timw.info/dss1**

Carry the frameworks into the rest of the path

The course: four modules, four instruments



Resilience: recovery leads, and the workload chooses the vault

MCRA and MCSB: capability map, then named controls

CAF and WAF: govern the estate, evaluate the workload

AI and DevSecOps: govern before adopting, enforce in the pipeline

Demo: Govern AI adoption before you enable it

Find the AI workloads Defender for Cloud has already discovered, then show the four decisions no dashboard records

Relevant SC-100 practice question

Globomantics teams are adopting AI without review.

Question

What do you recommend first?

A. Block consumer AI services at the network edge

B. Define AI security objectives and governance policy, then baseline

C. Deploy an approved enterprise AI service for every team

D. Add prompt-injection detection to the SOC playbooks

Checking out with Globomantics



Govern AI adoption before you enable it

Extend your frameworks rather than duplicating them

Attach controls at design, code, pipeline, and operations

Block the few controls that matter, report the rest

Thank you for your time!



Tim Warner | TechTrainerTim.com